API Rate Limiting Design

Our public API enforces per-API-key rate limits using a token bucket algorithm rather than a fixed window counter.

Each key is allocated a bucket with a capacity of 100 tokens, refilling at 10 tokens per second. A request consumes one token; if the bucket is empty the request is rejected with HTTP 429 and a Retry-After header.

Token buckets were chosen over fixed windows because they smooth out bursts: a client that has been idle can burst up to its full bucket capacity, but sustained traffic is capped at the refill rate rather than allowing a new burst at every window boundary.

Rate limit state is stored in Redis with a Lua script so the check-and-decrement is atomic across concurrent requests for the same key.